



POLÍTICA DE USO DE CRIPTOGRAFIA

Sistema de Gestión de Seguridad de la Información – Nivel Central

Código	PS-NC-15
Versión oficial:	V 1.0
Fecha de la versión:	09.03.2023
Elaborado por:	José Villa Catalan / Luciano Rojas
Revisado por:	Jose Villa – Encargado de Seguridad de la Información.
	Carlos Maldonado – Encargado Operaciones
	Rodrigo Zamorano – Encargado Proyectos
Aprobado por:	Jorge Herrera - Jefe Departamento de Tecnologías de la Información y Comunicaciones



Contenido

1	PROPÓSITO	2
2	ALCANCE O ÁMBITO DE APLICACIÓN	2
3	MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS	2
4	TERMINOLOGÍA	3
5	ROLES Y RESPONSABILIDADES.....	4
6	MATERIAS QUE ABORDA.....	4
7	DIRECTRICES DE LA POLÍTICA	4
7.1	Directrices de seguridad para todo el personal	5
7.2	Directrices de seguridad para el personal que trata información crítica.....	6
7.3	Cifrado para proteger los datos en reposo, en tránsito y en uso	6
7.4	Algoritmos no permitidos	7
8	MECANISMO DE DIFUSIÓN.	7
9	PERÍODO DE REVISIÓN.	7
10	CUMPLIMIENTO	7
11	HISTORIAL Y CONTROL DE VERSIONES.....	8
12	REFERENCIAS.....	8

1 PROPÓSITO

Establecer los requisitos para asegurar el uso adecuado y efectivo de la criptografía para proteger la confidencialidad, autenticidad e integridad de la información en la organización contra la divulgación no autorizada, la alteración o la destrucción.

2 ALCANCE O ÁMBITO DE APLICACIÓN

El alcance o ámbito de aplicación del presente documento se extiende a la Subsecretaría de Salud Pública y Subsecretaría de Redes Asistenciales.

Esta política es aplicable a todos los funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y de Redes Asistenciales.

Asimismo, se aplica a aquellos que traten información sensible, tengan derechos de acceso a la información que puedan afectar los activos de información y al personal encargado de implementar los controles de cifrado en los servicios de red y en los sistemas de información del Ministerio de Salud.

Esta política abarca el control definido en la norma NCh-ISO 27002:2013 sobre los controles de seguridad de la información:

- A.10.1 Controles criptográficos
- A.10.1.1 Política de uso de los controles criptográficos
- A.18.1.5 Regulación de los controles criptográficos

3 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS

- NCh-ISO IEC 27001:2013 Tecnología de la información – Técnicas de seguridad – Sistemas de gestión de la seguridad de la información – Requisitos
- NCh-ISO IEC 27002:2013 sobre Seguridad de información, ciberseguridad y protección de la privacidad – Controles de seguridad de la información.
- Ley N° 19.628, de Protección de vida privada y datos personales.
- Ley N° 19.799, de firmas y documentos electrónicos.
- Ley N° 19.927, de Delitos de Pornografía Infantil.
- Ley N° 20.285 regula el principio de transparencia de la función pública y el derecho de acceso a la información de los órganos de la Administración del Estado.
- Ley N° 21.180, de Transformación Digital del Estado.
- Ley N° 21.459, que Establece normas sobre Delitos Informáticos, deroga la Ley N°19.223 y modifica otros cuerpos legales con el Objeto de Adecuarlos al Convenio de Budapest.
- Decreto N° 83, 2004, Ministerio Secretaría General de la Presidencia, que aprueba norma técnica para los órganos de la administración del estado sobre seguridad y confidencialidad de los documentos electrónicos.
- El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
 - Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
 - Leyes relacionadas

Documentos Relacionados

- Política de Seguridad para la clasificación y manejo de información [1]

4 TERMINOLOGÍA

- i. **Cifrado:** que está escrito con letras, símbolos o números que solo pueden comprenderse si se dispone de la clave (llave criptográfica) necesaria para descifrarlos.
- ii. **Cifrar:** es un procedimiento que utiliza un algoritmo de cifrado con cierta clave (clave de cifrado) que transforma la información, sin atender a su estructura lingüística o significado, de tal forma que sea incomprensible o, al menos, difícil de comprender para cualquier persona que no tenga la clave secreta.
- iii. **Controles criptográficos:** son los procedimientos y mecanismos utilizados para proteger la información mediante el cifrado y descifrado de los datos.
- iv. **Datos personales o datos de carácter personal:** los datos relativos a cualquier información concerniente a personas naturales, identificadas o identificables, con independencia de su soporte.
- v. **Datos sensibles:** datos personales que se refieren a características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, tales como los hábitos personales, origen racial, las ideologías y opiniones políticas, las creencias o convicciones religiosas, los estados de salud físicos o psíquicos y la vida sexual.
- vi. **Datos en reposo:** se refiere a los datos que se encuentran almacenados y no se están utilizando activamente en un momento dado. Estos datos pueden ser almacenados en dispositivos físicos como discos duros, cintas magnéticas, servidores u otros métodos de almacenamiento.
- vii. **Datos en tránsito:** se refieren a los datos que se están moviendo de un dispositivo o lugar a otro, a través de una red o canal de comunicación. Estos datos pueden ser transmitidos a través de diferentes medios, como internet, redes privadas, líneas telefónicas, entre otros.
- viii. **Tratamiento de datos:** cualquier operación o complejo de operaciones o procedimientos técnicos de carácter automatizado o no, que permitan recolectar, almacenar, grabar, organizar, elaborar, seleccionar, extraer, confrontar, interconectar, disociar, comunicar, ceder, transferir, transmitir o cancelar datos de carácter personal, o utilizarlos en cualquier otra forma.
- ix. **Llaves criptográficas:** son códigos (algoritmos) que se generan de forma automática y se guarda en un directorio especial durante la instalación. Generalmente, esta información es una secuencia de números o letras que se utilizan en criptografía para especificar la transformación del texto plano en texto cifrado, o viceversa.
- x. **Texto plano:** es un archivo informático que contiene únicamente texto compuesto por caracteres que son legibles por humanos, sin ningún tipo de formato tipográfico. También son llamados archivos de texto llano, simple o sin formato.
- xi. **Nivel de clasificación:** se refiere a la categorización de la información en función de su nivel de confidencialidad.
 - **Secreto:** aquellos documentos e informaciones que requieren un nivel elevado de protección y confidencialidad, de acuerdo con lo establecido en esta Política y por el ordenamiento jurídico. Estos datos no pueden ser divulgados, salvo en situaciones específicamente autorizadas y debidamente registradas mediante actos o resoluciones que indiquen su clasificación como secretos.
 - **Reservado:** información altamente sensible y de uso exclusivamente interno. Su divulgación podría implicar un impacto no deseado para el Ministerio de Salud (MINSAL) o podría vulnerar la normativa vigente. Para su protección, debe ser declarada como

reservada considerando lo dispuesto en la Ley 20.285, sobre acceso a la información pública.

- **Pública:** Es toda información que el Ministerio de Salud (MINSAL) genere, obtenga, adquiera, o controle; corresponde a datos que son de acceso público y, que por lo tanto, no tienen requerimientos frente a la Confidencialidad.

Uso interno: Es toda información que no contiene datos sensibles, que puede encontrarse en proceso de construcción, y que está disponible para todos los empleados y terceros seleccionados. Esta información puede ser entregada al público sujeto a la normativa vigente, previa consulta al propietario del activo.

5 ROLES Y RESPONSABILIDADES

Para asegurar el uso adecuado y efectivo de la criptografía para proteger la confidencialidad, autenticidad e integridad de la información en la organización, se definen los siguientes roles y responsabilidades:

i. Departamento TIC

- Garantizar que todo sistema de información que requiera realizar transmisión de información clasificada de acuerdo con nivel de confidencialidad cuente con mecanismos de cifrado de datos. Para este propósito deberá proveer los métodos de cifrado de la información que se requieran.

ii. Encargado de Seguridad de la Información

- Velar por el cumplimiento de la presente política para garantizar que la información sea tratada de acuerdo con el nivel de confidencialidad al momento de almacenarse o transmitirse por cualquier medio.

iii. Personal encargado de la configuración de encriptación

- Deberá configurar y administrar el sistema de cifrado, así como velar por el cumplimiento de la presente política y generar los reportes que se requieran.

iv. Dueño del activo (Propietario de la información)

- Garantizar el cifrado de la información de acuerdo con su clasificación en función a su nivel de confidencialidad y que se traten dentro del desarrollo de sus actividades para con el MINSAL.

6 MATERIAS QUE ABORDA.

- Directrices de cifrado para propietarios de la información y personal en general.
- Tipos de cifrado para proteger los datos en reposo, en tránsito y en uso.

7 DIRECTRICES DE LA POLÍTICA

Con el fin de garantizar la confidencialidad e integridad de los documentos según su nivel de clasificación, el MINSAL deberá utilizar sistemas y técnicas criptográficas para la protección de la información.

Se deberán utilizar algoritmos criptográficos aprobados por los estándares de la industria. El Departamento de Tecnologías de la Información y Comunicaciones (TIC) del MINSAL, evaluará

y actualizará periódicamente la selección de algoritmos en función de los cambios de estos estándares e implementará medidas de seguridad para proteger los datos cifrados, incluyendo la autenticación de usuarios y la gestión de acceso a los datos cifrados.

Los sistemas de información ministeriales deberán contar con mecanismos de protección de la información, que cumplan con lo indicado en la presente política. Además de cumplir con estas directrices, se deben considerar los siguientes aspectos:

- Identificar el nivel de protección requerido y la clasificación de la información, estableciendo en consecuencia el tipo y calidad de los algoritmos criptográficos requeridos.
- Proporcionar una protección adecuada a los equipos utilizados para generar, almacenar y archivar claves, considerándolo crítico o de alto riesgo.
- Proteger las claves secretas y privadas evitando sean copiadas o modificadas sin autorización.

Se deberá asegurar que la información bajo custodia o propiedad se cifre de acuerdo con el nivel de confidencialidad al momento de ser almacenada o transmitida por cualquier medio.

Con el fin de cumplir con el tratamiento definido para los activos de información, es necesario que todos los involucrados en el alcance de esta Política, cumplan con las siguientes directrices:

7.1 Directrices de seguridad para todo el personal

- i. Implementar controles criptográficos y cifrados seguros, dependiendo proporcionalmente de la clasificación de la información que se maneja, en las ubicaciones que se almacenen datos en reposo y las copias de estas, para resguardar la confidencialidad e integridad de la información, incluidos los servicios cloud.
- ii. Hacer uso de técnicas de encriptación apropiadas para la protección de la información contenida en los dispositivos terminales de los usuarios móviles o medios de almacenamiento y transmitidos a través de redes a dichos dispositivos o medios de almacenamiento.
- iii. La información que contenga contraseñas de usuario o claves para el control de acceso a los sistemas de información no podrán ser almacenadas en texto plano y deberá hacer uso de mecanismos criptográficos.
- iv. Los documentos que se han cifrado y descifrado, en caso de que se requiera, deberán ser almacenados y tratados con las medidas de seguridad requeridas conforme al nivel de clasificación de la información.
- v. Identificar todo sistema de información que requiera realizar transmisión de información de conformidad al nivel de su clasificación, para así garantizar que cuente con mecanismos de cifrado de datos.
- vi. Cifrar los discos duros de los equipos computacionales que contengan información crítica.
- vii. En el caso del correo electrónicos, implementar y controlar los datos confidenciales, en cuyo caso el mensaje y archivo adjuntos deben ser encriptados.
- viii. Los acuerdos de nivel de servicio o contratos con proveedores externos de servicios criptográficos, como una autoridad de certificación, deberán abordar aspectos de responsabilidad, confiabilidad de los servicios y tiempos de respuesta para la prestación de servicios.
- ix. El manejo de llaves criptográficas se debe realizar de acuerdo con los lineamientos establecidos en la **Política de Llaves Criptográficas del Ministerio de Salud**.

7.2 Directrices de seguridad para el personal que trata información crítica.

- i. Cifrar los documentos lógicos, cuando contengan información clasificada, en particular los documentos importantes para las funciones y objetivos del MINSAL.
- ii. Se deberán cifrar o aplicar claves a los documentos (pdf, Excel, Word, bd, csv, etc.) que contengan datos personales o datos sensibles.
- iii. La entrega de la clave del documento debe realizarse a través de un medio diferente al del envío del archivo.

7.3 Cifrado para proteger los datos en reposo, en tránsito y en uso

Se deben establecer requisitos de cifrado para cada estado de los datos, los cuales deben ser revisados y actualizados regularmente para garantizar que sigan siendo adecuados para proteger los datos de la organización contra las amenazas de seguridad actuales.

- i. Para garantizar la encriptación de los datos en reposo y proteger la información confidencial contra accesos no autorizados o malintencionados, es necesario seleccionar algoritmos de encriptación seguros y reconocidos por la comunidad informática. Estos algoritmos deben ser adecuados según las necesidades de disponibilidad de hardware y software compatible, la seguridad y estandarización del algoritmo en cuestión, y requisitos de seguridad específicos para proteger la información almacenada en dispositivos como discos duros, unidades flash USB y bases de datos.
- ii. Algoritmos de encriptación aceptados
 - AES (Advanced Encryption Standard),128 bits y superior (192 y 256) cifrado simétrico.
 - Algoritmo de HASH, familia SHA-2 o 3 (Secure Hash Algoritm).
- iii. Para la encriptación de datos en tránsito y proteger de los datos que se envían a través de redes como Internet o redes privadas. Se deberán utilizar:
 - SSL/TLS, utilizar protocolos de seguridad SSL (Secure Sockets Layer) y TLS (Transport Layer Security) en su versión más reciente para asegurar la comunicación entre clientes y servidores a través de Internet, incluyendo el cifrado de datos y la autenticación del servidor.
 - Internet Protocol Security (IPSec) para proporcionar seguridad en la capa de red de la comunicación en Internet., utilizado en redes privadas virtuales (VPN) y en conexiones de red de área amplia (WAN).
 - Los servidores web que admitan conexiones seguras deberán tener un certificado SSL instalado.
 - El transporte de archivos confidenciales a través de SFTP, FTPS, SCP o similares, requerirá de cifrado para acceder a datos confidenciales desde cualquier dispositivo con una interfaz web.
- iv. Para los datos en uso, que se procesan en una computadora o dispositivo móvil, se debe utilizar un software de encriptación adecuado. Este software debe configurarse con una clave de encriptación segura y se deben seleccionar los archivos que serán encriptados. Además, es importante mantener la clave de encriptación protegida en un lugar seguro.

A continuación, los softwares de encriptación recomendables para para proteger los datos en uso:

- Microsoft Office, la suite de productividad de Microsoft Office 365 que incluye Word, Excel y PowerPoint, ofrece una función de protección de archivos llamada "Proteger documento". Esta función permite encriptar los documentos de Office mientras se utilizan y descripta automáticamente al guardarlos y cerrarlos.

POLÍTICA DE USO DE CRIPTOGRAFIA			
	Sistema de Gestión de Seguridad de la Información – Nivel Central		
	MINISTERIO DE SALUD	ID: PS-NC- 15	Versión: 1 Página 7 de 8

- BitLocker, es un software de encriptación de Microsoft que está disponible en Windows 10 Pro, Enterprise y Education. Permite encriptar discos duros y dispositivos de almacenamiento externos.
- Otros softwares de código abierto:
 - GPG Suite, software de encriptación de correo electrónico y archivos de código abierto que es compatible con Mac. Incluye una herramienta llamada "GPSServices" que permite encriptar y desencriptar archivos en tiempo real.
 - VeraCrypt, además de ser un software de encriptación de datos en reposo, también puede encriptar datos en uso.
 - AxCrypt, software de encriptación de archivos de código abierto que es compatible con Windows.

7.4 Algoritmos no permitidos

- DES (IDEA), obsoleto. Remplazado desde el 2002 por el algoritmo AES.
- MD4 y MD5 (hash) No aprobado por el NIST.
- SHA1 (hash).
- 3DES.
- RC1, RC2, RC3, RC4; CAST o CAST 128; Blowfish
- RSA o DSA con largo de llaves igual o inferior a 1024-bits.
- Criptografía basada en curvas elípticas con largo de llaves igual o inferior a 160 bits.
- Los protocolos de transporte en sus versiones más antiguas e inseguras como el TLS 1.0 y TLS 1.1.
- Cualquier tipo de algoritmo no aprobado por la comunidad internacional o implementaciones caseras locales.

8 MECANISMO DE DIFUSIÓN.

La comunicación de la presente política se realizará de manera accesible y comprensible todos los usuarios. Se difundirá a través de los siguientes canales al menos:

- Publicación en el sitioweb de Minsal http://www.minsal.cl/seguridad_de_la_informacion/
- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

9 PERÍODO DE REVISIÓN.

- La presente política deberá ser revisada a lo menos cada dos años o cuando ocurran cambios significativos para garantizar que:
 - Sigue siendo adecuada para su propósito.
 - Refleje los cambios en las tecnologías, algoritmos y cifradores.
 - Está alineada con las mejores prácticas de la industria.
 - Respalde el cumplimiento normativo, contractual y legal continuo.

A su vez, se realizarán actualizaciones cada vez que se produzcan “colisiones criptográficas” exitosas a los algoritmos válidos.

10 CUMPLIMIENTO

El incumplimiento de esta política puede resultar en acciones disciplinarias, incluyendo la terminación del empleo o la cancelación del acceso a los sistemas de información de la organización.

11 HISTORIAL Y CONTROL DE VERSIONES

Versión	Fecha	Creado por	Pág. o Sección modificada	Descripción de la modificación
1.0	09.03.2023	José Villa C.	Todas	Creación del documento

12 REFERENCIAS

[1]. SITIO WEB MINSAL – Política de Seguridad para la clasificación y manejo de información – <http://www.minsal.cl/seguridad de la informacion/>